

## 1.2 Operating System Privileged Account Control

| Control Type: Mandatory / Advisory for B                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              | Applies to architecture: | A1 | A2 | A3 | A4 | B |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|----|----|----|----|---|
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |                          | •  | •  | •  | •  | • |
| <p><b><u>Control Definition</u></b></p> <p><b>Control Objective:</b> Restrict and control the allocation and usage of administrator-level operating system accounts.</p> <p><b>In-scope components:</b></p> <p>Administrator-level accounts defined on the following components:</p> <ul style="list-style-type: none"> <li>• systems or virtual machines (VMs) hosting a Swift-related component (including interface, GUI, Swift or customer (client) connector, jump server)</li> <li>• systems or VMs hosting a customer client connector</li> <li>• dedicated operator PCs</li> <li>• network devices protecting the secure zone or the customer client connectors</li> <li>• on-premises or remote (that is hosted or operated by a third party, or both) virtualisation or cloud platform that hosts Swift-related VMs, including the Alliance Connect Virtual on Premises VPN</li> <li>• New HSM</li> <li>• customer client connector</li> <li>• bridging servers (such as middleware or file transfer servers other than customer connectors) used for and <b>guardian of the secure data</b> exchange between back-office and Swift-related components</li> <li>• [Advisory: General-purpose operator PCs]</li> </ul> <p><b>Risk Drivers:</b></p> <ul style="list-style-type: none"> <li>• deletion of logs and forensic evidence</li> <li>• excess privilege or access</li> <li>• lack of traceability</li> <li>• unauthorised system changes</li> <li>• HSM management misused</li> </ul> |                          |    |    |    |    |   |
| <p><b><u>Implementation Guidance</u></b></p> <p><b>Control Statement:</b></p> <p>Access to administrator-level operating system accounts is restricted to the maximum extent possible. Usage is controlled, monitored, and only permitted for relevant activities such as software installation and configuration, maintenance, and emergency activities. At all other times, an account with the least privilege access is used.</p> <p><b>Control Context:</b></p> <p>Tightly protecting administrator-level accounts within the operating system reduces the opportunity for an attacker to use the privileges of the account as part of an attack (for example, executing commands or deleting evidence).</p> <p><b>Implementation Guidelines:</b></p> <p>The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives).</p> <ul style="list-style-type: none"> <li>• Examples of administrator-level accounts are defined as follows:</li> </ul>                                                            |                          |    |    |    |    |   |

- Windows: built-in administrator account and members of groups with administrator privileges (for example, accounts with debug or file system privileges). Typically, Enterprise Admins group, Domain Admins group, and Local Administrator group.
- Linux/Unix: root account (User ID = 0) and members of the root group.
- Mainframe: system administrator or system programmer role.
- Network devices: accounts like admin, root, telco, su or cisco.
- New HSM: admin accounts.
- Virtualisation or cloud platform: administrator, super admin, root user or the like accounts.
- Access to administrator-level operating system accounts is restricted to the maximum extent possible unless needed to install, configure, maintain, operate, or support emergency activities. The use of the administrator-level account is limited to the duration of the activity (for example, maintenance windows).
- Logins with built-in administrator-level accounts are not permitted, except to perform activities where such accounts are specifically needed (for example, system configuration) or in emergency situations (break-glass account). Individual accounts with administrator-level privileges or accounts with the ability to escalate to administrative access, (like “sudo”) are used instead. Break-glass account usage must be strictly controlled (with password physically or digitally safe-stored and requiring authorisation before retrieval) and monitored (in line with or as part of the control 6.4). In addition, the passwords must be changed once used to ensure accountability, prevent misuse, or account compromise.
- Individual administrator-level account access and usage are logged, in line with or as part of the control 6.4, so that activities can be reconstructed to help determine the root-cause of incidents.
- Administrator-level passwords are tightly controlled with physical access controls when physically recorded.

#### Optional Enhancements:

- Systems are configured to disallow logins of built-in administrator-level accounts, except through a maintenance mode (for example, single user mode or safe mode). This effectively prohibits logins to the account as a service, batch job, through remote desktop services, or by escalating privileges from another account.
- Apply the control to all bridging servers (such as middleware or file transfer servers other than customer connectors) used for data exchange between back-office and Swift-related components.

#### Considerations for alternative implementations:

New models are emerging to enhance the user experience but also availability as observed with the pandemic. Alternative implementations are raising to give users flexible access to the institutions' environment: not necessarily through fully managed devices<sup>16</sup> but incorporating also individuals own devices to reach resources located on premises or in the cloud. That implies moving from a controlled on-premises environment (for which the CSCF mainly provides guidance) to a zero-trust environment requiring to assess and control appropriately each type of access.

Such alternatives have to be considered individually and specifically by users from a risk-based point of view taking into consideration potential risks if some elements are compromised. Those alternatives cannot be described here but would require to consider elements such as those identified below for a secure virtual desktop infrastructure:

- Defining a virtual desktop infrastructure (Citrix or other workspace) with OS privileged account managed centrally and not possibly activated or used by the end users can meet the control (considering the virtual infrastructure is protected in line with control 1.3 and the virtual desktops themselves are protected as a physical general-purpose operator PC in line with control such as 2.2, 2.3, 2.7, 4.1, 5.1; 6.1; 6.4, 6.5A).
- The risks of end-user device compromise must be considered, analysed and appropriate controls deployed to protect the virtual desktop infrastructure and further accessed resources. Those controls must ensure proper authentication, activities authorisation (requesting sometimes additional independent factors) but also appropriate prompt reaction, also involving the end users, in case of end-user device compromise, loss or theft to block potential accesses through such device.

<sup>16</sup> Fully managed device is a company-owned device with features that give IT admins control of the device settings and policy configuration, including potential remote-wipe in case of theft/loss. At the opposite of the spectrum, there is the use of unmanaged (by a company) individuals own device to access the company resources, network or applications hosted in the cloud or with a service provider. Intermediary models can exist where managed (sand-boxed) application(s) (by a company) are deployed on users own device (potentially with the capability to remote-wipe those applications in case of device theft/loss). All those models have to be properly analysed for proper and secure usage.

- Confidentiality and integrity of the sessions established towards the virtual infrastructure must also be ensured in line with the standard operator session depicted in control 2.6.